

9-Passwords - A Cracking Christmas

Introduction



Con la inestabilidad del periodo entre Pascua y Navidad, los sistemas, antes silenciosos, de The Best Festival Company comenzaron a mostrar rastros de datos cifrados ocultos en las profundidades de sus servidores. Sir Carrotbane se topó con una serie de archivos PDF y ZIP bloqueados, etiquetados como "Lista de Activos del Polo Norte". Corrieron rumores de que podrían contener fragmentos del registro de regalos de Papá Noel, información crucial que podría ayudar a Malhare a controlar el equilibrio festivo entre ambos mundos.

Sir Carrotbane se propone descifrar el cifrado y descubre cómo las contraseñas débiles pueden exponer incluso los secretos más guardados. ¿Podrán los Elfos adaptarse rápidamente y evitar que se descubran sus secretos?

Objetivos de aprendizaje

- Cómo el cifrado basado en contraseñas protege archivos como PDF y ZIP.
- Por qué las contraseñas débiles hacen vulnerables los archivos cifrados.
- Cómo los atacantes utilizan ataques de diccionario y fuerza bruta para recuperar contraseñas.
- Un ejercicio práctico: descifrar la contraseña de un archivo cifrado para revelar su contenido.
- La importancia de usar contraseñas seguras y complejas para defenderse de estos ataques.

Algunos puntos sencillos para recordar:

- La solidez de la protección depende casi por completo de la contraseña. Las contraseñas cortas o comunes se pueden adivinar; las contraseñas largas y aleatorias son mucho más difíciles de descifrar.
- Los diferentes formatos de archivo utilizan distintos algoritmos y métodos de derivación de claves. Por ejemplo, el cifrado de PDF y el cifrado ZIP difieren en detalles (cómo se deriva la clave, uso de sal, número de iteraciones de hash). Esto afecta la facilidad o dificultad de descifrado.
- Muchas herramientas de consumo aún admiten modos heredados o débiles (en particular, el cifrado ZIP más antiguo). Esto hace que algunos archivos cifrados sean mucho más fáciles de atacar que los esquemas modernos bien implementados.
- El cifrado solo protege la confidencialidad de los datos. No impide que alguien con acceso al archivo cifrado intente adivinar la contraseña sin conexión.

En resumen, el cifrado hace que el contenido sea ilegible a menos que se conozca la contraseña correcta. Si la contraseña es débil, un atacante puede simplemente probar contraseñas probables hasta que una funcione.

Connecting to the Machine

Before moving forward, review the questions in the connection card shown below:

Start your target machine by clicking the **Start Machine** button below. The machine will need about 2 minutes to fully boot. In case you can not see it, click the **Show Split View** button at the top of the page.

Alternatively, you can use the credentials below to connect to the target machine via SSH from your own THM VPN connected machine:

Credentials

Only needed if you are using your own THM VPN connected machine.

Username	Password	IP address	Connection via
 ubuntu	 AOC2025Ubuntu!	 MACHINE_IP	 SSH <code>ssh ubuntu@MACHINE_IP</code>

Attacks Against Encrypted Files

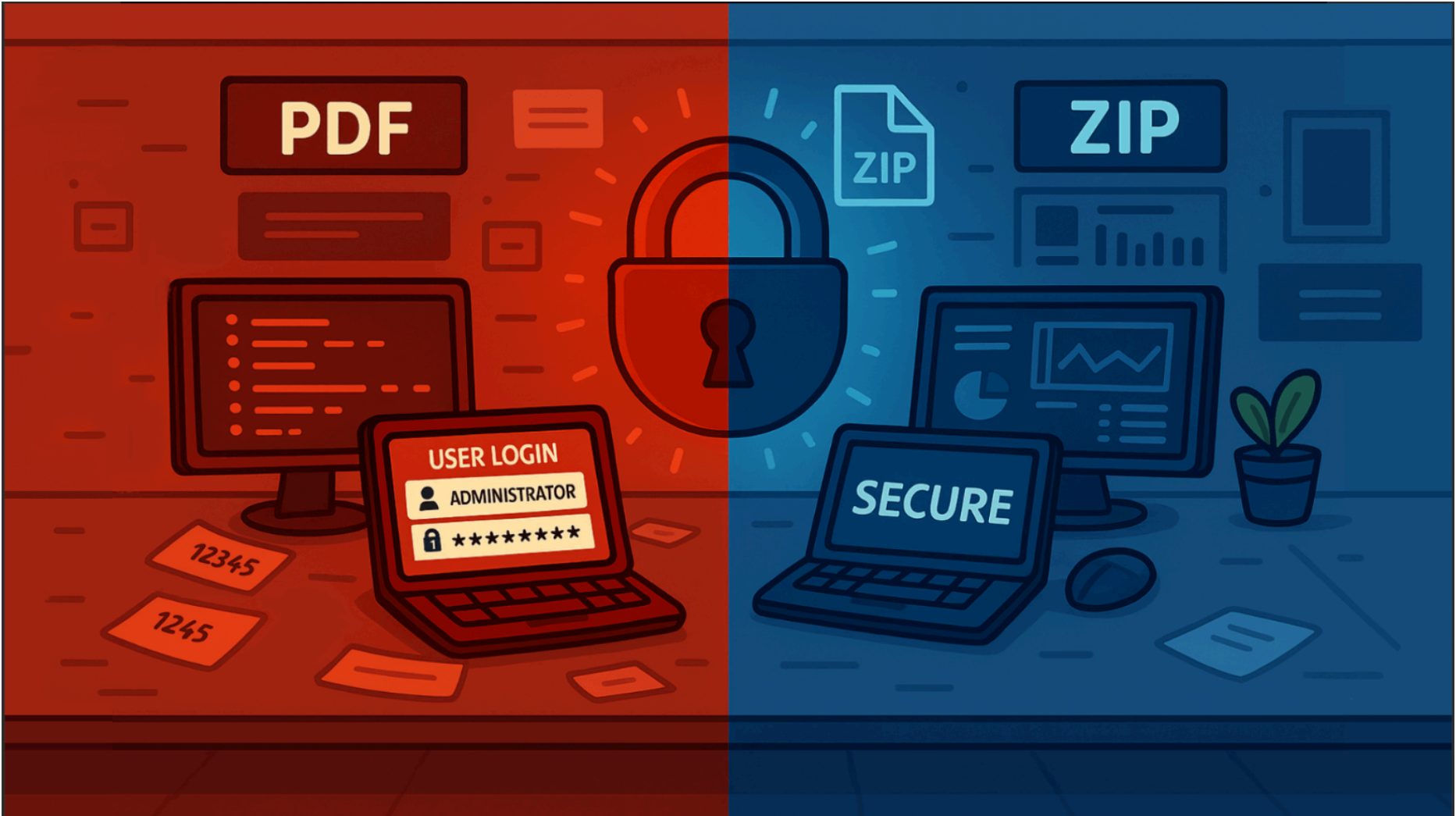
Cómo recuperan los atacantes contraseñas débiles

Los atacantes no suelen intentar romper el cifrado en sí, ya que esto llevaría demasiado tiempo con la criptografía moderna. En cambio, se centran en adivinar la contraseña que protege el archivo. Las dos formas más comunes de hacerlo son los ataques de diccionario y los ataques de fuerza bruta (o de enmascaramiento).

Ataques de diccionario

En un ataque de diccionario, el atacante utiliza una lista predefinida de posibles contraseñas, conocida como lista de palabras, y prueba cada una hasta encontrar la contraseña correcta. Estas listas de palabras suelen contener contraseñas filtradas de filtraciones anteriores, sustituciones comunes como "password123", combinaciones predecibles de nombres y fechas, y otros patrones que los usuarios usan con frecuencia. Dado que muchos usuarios eligen contraseñas débiles o comunes, los ataques de diccionario suelen ser rápidos y muy eficaces.

Ataques con máscara



Los ataques de fuerza bruta y de máscara van un paso más allá. Un ataque de fuerza bruta prueba sistemáticamente todas las combinaciones posibles de caracteres hasta encontrar la correcta. Si bien esto garantiza el éxito a largo plazo, el tiempo necesario aumenta exponencialmente con la longitud y la complejidad de la contraseña.

Los ataques de máscara buscan reducir ese tiempo limitando las suposiciones a un formato específico. Por ejemplo, probando todas las combinaciones de tres letras minúsculas seguidas de dos dígitos.

Al limitar el espacio de búsqueda, los ataques de máscara logran un equilibrio entre velocidad y minuciosidad, especialmente cuando el atacante tiene alguna idea de cómo podría estar estructurada la contraseña.

Consejos prácticos que usan los atacantes (y que los defensores deberían conocer):

- Comienza con una lista de palabras (victorias rápidas). Listas comunes: `rockyou.txt` , `common-passwords.txt` .
- Si la lista de palabras falla, pasa a listas de palabras específicas (nombres de empresas, nombres de proyectos o datos del objetivo). Si esto falla, intente usar ataques de máscara o incrementales en contraseñas cortas (p. ej., `?l?l?l?d?d` = tres letras minúsculas + dos dígitos, que las herramientas de descifrado de contraseñas utilizan como formato de máscara de contraseña).
- Utilice el descifrado acelerado por GPU siempre que sea posible; acelera drásticamente los ataques de algunos algoritmos.
- Vigile el uso de recursos: el descifrado consume muchos recursos de la CPU y la GPU. Este comportamiento se puede detectar en un endpoint monitorizado.

Ejercicio

Encontrarás los archivos de esta sección en el directorio del escritorio de tu equipo. Accede a él ejecutando "cd Desktop" en tu terminal.

1. Confirma el tipo de archivo

Usa el comando "file" o abre el archivo con un visor hexadecimal. Esto te ayudará a elegir la herramienta adecuada.

```
File Command
ubuntu@tryhackme :~/Desktop$ file flag.pdf
ubuntu@tryhackme :~/Desktop$ file flag.zip
```

Si es un PDF, proceda con herramientas PDF. Si es un ZIP, proceda con herramientas ZIP.

2. Herramientas a usar (elija una según el tipo de archivo)

- **PDF:** pdftcrack, john (vía pdf2john)
- **ZIP:** fcrackzip, john (vía zip2john)
- **General:** john (muy flexible) y hashcat (aceleración de GPU, más avanzado)

3. Pruebe primero un ataque de diccionario (rápido, suele tener éxito)

Ejemplo: PDF con pdftcrack y rockyou.txt:

PdfCrack Command

```
ubuntu@tryhackme :~/Desktop$ pdfcrack -f flag.pdf -w /usr/share/wordlists/rockyou.txt
PDF version 1.7
Security Handler: Standard
V: 2
R: 3
P: -1060
Length: 128
Encrypted Metadata: True
FileID: 3792b9a3671ef54bbfef57c6fe61ce5d
U: c46529c06b0ee2bab7338e9448d37c3200000000000000000000000000000000
O: 95d0ad7c11b1e7b3804b18a082dda96b4670584d0044ded849950243a8a367ff
Average Speed: 29538.5 w/s. Current Word: 's8t8a8r8'
Average Speed: 31068.0 w/s. Current Word: 'toby344'
Average Speed: 30443.7 w/s. Current Word: 'erikowa'
Average Speed: 29519.3 w/s. Current Word: '0848845800'
Average Speed: 29676.4 w/s. Current Word: 'u3904041'
Average Speed: 29339.8 w/s. Current Word: 'spider0187'
Average Speed: 30156.8 w/s. Current Word: 'roermond7'
Average Speed: 30364.8 w/s. Current Word: 'papaopass2'
found user-password: 'XXXXXXXXXX'
```

Ejemplo: usando john

Crea un hash que John pueda entender: zip2john flag.zip > ziphash.txt

Terminal

```
ubuntu@tryhackme:~/Desktop$ zip2john flag.zip > ziphash.txt
```

John informará la contraseña recuperada si encuentra una.

Terminal

```
ubuntu@tryhackme:~/Desktop$ john --wordlist=/usr/share/wordlists/rockyou.txt ziphash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 128/128 AVX 4x])
Cost 1 (HMAC size) is 29 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
XXXXXXXXXX      (flag.zip/flag.txt)
1g 0:00:02:12 DONE (2025-10-03 08:26) 0.007552g/s 20696p/s 20696c/s 20696C/s winternights..wine23
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

DetECCIÓN DE INDICADORES Y TELEMETRÍA

El descifrado de contraseñas sin conexión no afecta a los servicios de inicio de sesión, por lo que los bloqueos y los paneles de inicio de sesión fallidos permanecen ocultos. Podemos detectar el trabajo donde se ejecuta, en endpoints y jump boxes. Las señales importantes a monitorear incluyen:

Creación de procesos: El descifrado de contraseñas cuenta con un pequeño conjunto de binarios y patrones de comandos conocidos que podemos detectar. Una combinación de eventos de proceso, actividad de archivos, señales de GPU y toques de red vinculados a herramientas y listas de palabras. Nuestro objetivo es que la actividad sea obvia sin que se filtre en el ruido.

- Binarios y alias: john, hashcat, fcrackzip, pdfcrack, zip2john, pdf2john.pl, 7z, qpdf, unzip, 7za, Perl invocando pdf2john.pl.
- Características de la línea de comandos: --wordlist, -w, --rules, --mask, -a 3, -m en Hashcat, referencias a rockyou.txt, SecLists, zip2john, pdf2john.
- Archivos Pot y estado: ~/.john/john.pot, .hashcat/hashcat.potfile, john.rec.

Vale la pena señalar que en los sistemas Windows, Sysmon Event ID 1 captura la creación de procesos con propiedades de línea de comando completas, mientras que en Linux, los sensores auditd, execve o EDR capturan binarios y argumentos.



Artefactos de GPU y Recursos

El crackeo de la GPU es muy frecuente. Se puede detectar un uso excesivo y repentino en los hosts, lo cual debería investigarse.

- nvidia-smi muestra procesos de larga duración llamados hashcat o john.
- Uso y consumo de energía de la GPU altos y constantes mientras la curva del ventilador se dispara.
- Bibliotecas cargadas: nvcuda.dll, OpenCL.dll, libcuda.so, amdocl64.dll.

Consejos de red, Ligeros pero útiles

El crackeo sin conexión no necesita la red una vez que las listas de palabras están presentes. Sin embargo, la mayoría de los operadores obtienen primero las listas y las herramientas.

- Descargas de archivos de texto grandes llamados rockyou.txt o clones de Git de repositorios de listas de palabras populares.
- Instalaciones de paquetes, por ejemplo, apt install john hashcat, detectadas por la telemetría de paquetes EDR.
- Actualizaciones de herramientas y obtención de controladores para tiempos de ejecución de la GPU.

Lecturas inusuales de archivos

Las lecturas repetidas de archivos, como listas de palabras o archivos cifrados, requieren análisis.

Detecciones

A continuación, se muestran algunos ejemplos de reglas de detección y consultas de búsqueda que podemos utilizar en diversos entornos.

Sysmon:

```
(ProcessName="C:\Program Files\john\john.exe" OR
ProcessName="C:\Tools\hashcat\hashcat.exe" OR
CommandLine="*pdf2john.pl*" OR
CommandLine="*zip2john*")
```

Reglas de auditoría de Linux, temporales para una investigación:

```
auditctl -w /usr/share/wordlists/rockyou.txt -p r -k wordlists_read
auditctl -a always,exit -F arch=b64 -S execve -F exe=/usr/bin/john -k crack_exec
auditctl -a always,exit -F arch=b64 -S execve -F exe=/usr/bin/hashcat -k crack_exec
```

Regla de estilo Sigma, proceso de Windows creado para herramientas de cracking:

```

title: Password Cracking Tools Execution
id: 9f2f4d3e-4c16-4b0a-bb3a-7b1c6c001234
status: experimental
logsource:
  product: windows
  category: process_creation
detection:
  selection_name:
    Image|endswith:
      - '\john.exe'
      - '\hashcat.exe'
      - '\fcrackzip.exe'
      - '\pdfcrack.exe'
      - '\7z.exe'
      - '\qpdf.exe'
  selection_cmd:
    CommandLine|contains:
      - '--wordlist'
      - 'rockyou.txt'
      - 'zip2john'
      - 'pdf2john'
      - '--mask'
      - '-a 3'
  condition: selection_name or selection_cmd
level: medium

```

Manual de Respuesta

Como analistas de seguridad en Wareville, es importante contar con un manual de respuesta cuando se producen este tipo de incidentes. Las acciones inmediatas a tomar son:

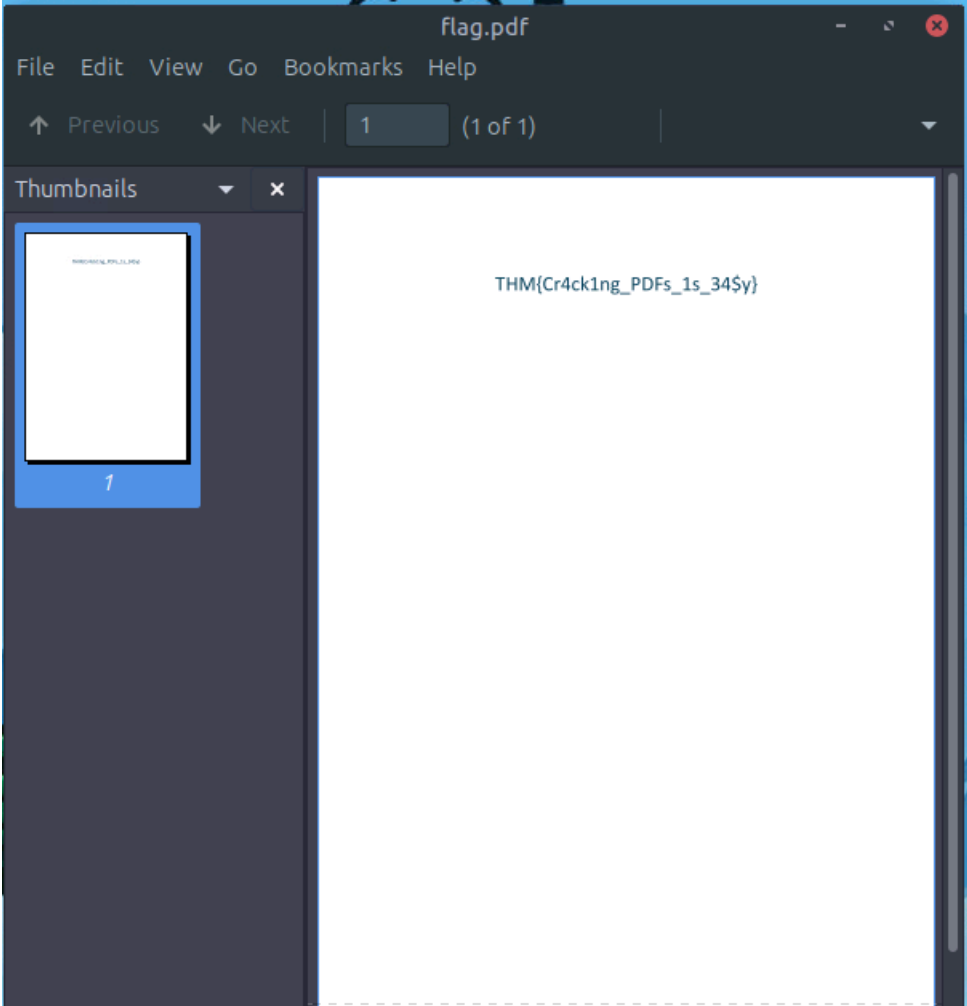
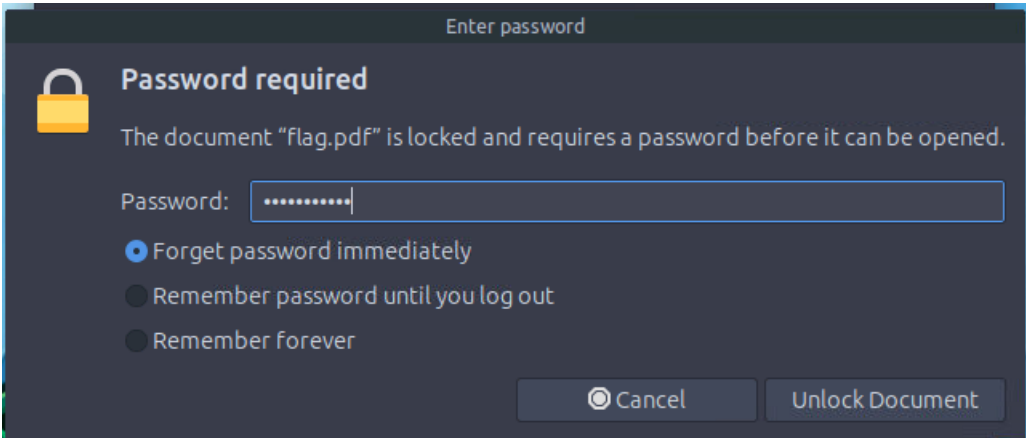
1. Aislar el host si se detecta actividad maliciosa. Si se trata de un laboratorio, etiquetar y suprimir.
2. Capturar artefactos de triaje como la lista de procesos, el volcado de memoria del proceso, la salida de muestra de nvidia-smi, los archivos abiertos y el archivo cifrado.
3. Conservar el directorio de trabajo, las listas de palabras, los archivos hash y el historial del shell.
4. Revisar qué archivos se descifraron. Buscar accesos posteriores, movimientos laterales o exfiltración.
5. Identificar el origen y la intención de la actividad. ¿Estaba autorizada? De no ser así, escalar al equipo de IR.
6. Remediar la actividad, rotar las claves y contraseñas afectadas y aplicar la autenticación multifactor (MFA) en las cuentas.
7. Cerrar con capacitación y la correcta colocación de las herramientas en entornos de pruebas aprobados.

Answer the questions below

What is the flag inside the encrypted PDF?

Respuesta: THM{Cr4ck1ng_PDFs_1s_34\$y}

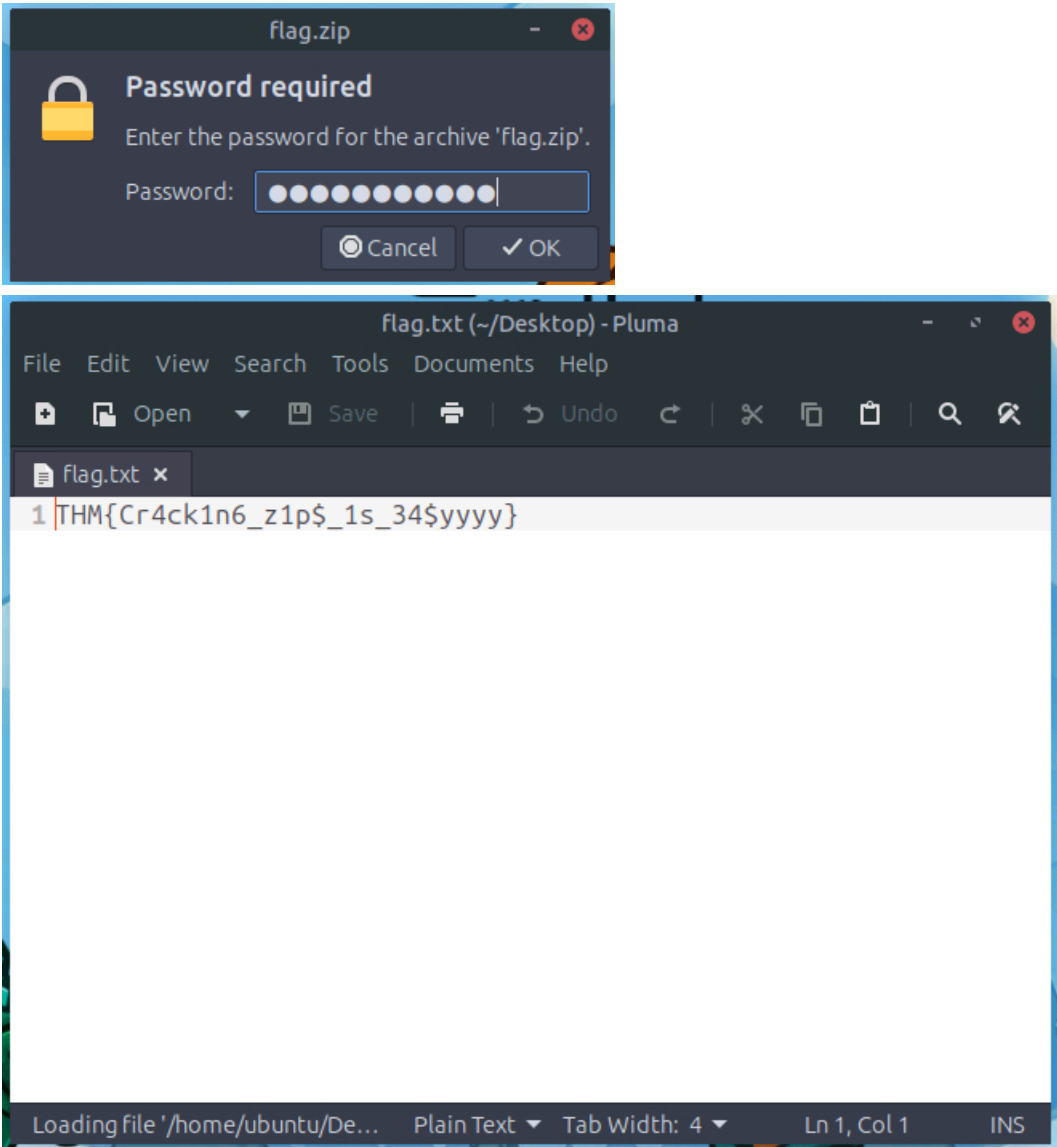
```
ubuntu@tryhackme:~/Desktop$ pdftocrack -f flag.pdf -w /usr/share/wordlists/rockyou.txt  
PDF version 1.7  
Security Handler: Standard  
V: 2  
R: 3  
P: -1060  
Length: 128  
Encrypted Metadata: True  
FileID: 3792b9a3671ef54bbfef57c6fe61ce5d  
U: c46529c06b0ee2bab7338e9448d37c320000000000000000000000000000000000  
O: 95d0ad7c11b1e7b3804b18a082dda96b4670584d0044ded849950243a8a367ff  
found user-password: 'naughtylist'  
ubuntu@tryhackme:~/Desktop$
```



What is the flag inside the encrypted zip file?

Respuesta: THM{Cr4ck1n6_z1p\$_1s_34\$yyyy}

```
ubuntu@tryhackme:~/Desktop$ zip2john flag.zip > ziphash.txt
ubuntu@tryhackme:~/Desktop$ cat ziphash.txt
flag.zip/flag.txt:$zip2$*0*3*0*db58d2418c954f6d78aefc894faebf54*d89c*1d*b8370111f4d9eba3ca
5ff6924f8c4ff8636055dce00daec2679f57bde1*57445596ac0bc2a29297*$ /zip2$:flag.txt:flag.zip:fl
ag.zip
ubuntu@tryhackme:~/Desktop$ john --wordlist=/usr/share/wordlists/rockyou.txt ziphash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 256/256 AVX2 8x])
Cost 1 (HMAC size [KiB]) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
winter4ever (flag.zip/flag.txt)
1g 0:00:00:00 DONE (2025-12-09 20:56) 2.041g/s 8359p/s 8359c/s 8359C/s friend..sahara
Use the "--show" option to display all of the cracked passwords reliably
Session completed
ubuntu@tryhackme:~/Desktop$
```



For those who want another challenge, have a look around the VM to get access to the key for **Side Quest 2!** Accessible through our [Side Quest Hub](#)!

Check

If you enjoyed this task, feel free to check out the [Password Attacks](#) room.

Check

parte 2

Hopper, el Bufón de la Corte

Érase una vez un genio del equipo rojo que se convirtió en bufón de la corte... nuestra historia comienza con Hopper. Antaño temido como el despiadado Jefe del Batallón de Conejitos del Equipo Rojo, Hopper ascendió al rango de Coronel con una velocidad vertiginosa. El ascenso lo llenó de tal euforia y ansia que consumía cada pensamiento. Sus soldados confundieron su creciente tic con estrés y comenzaron a llamarlo "Coronel Pánico", pero la verdad era mucho más peligrosa: el tic provenía de su obsesión por el poder, no por el miedo.

En aquellos días, Hopper ya había desempeñado un papel crucial, aunque convenientemente olvidado, en los primeros rumores del asedio de Wareville. Enterrados bajo el secreto y negados por la corona, esos primeros experimentos para traspasar las nuevas fronteras digitales fueron diseño de Hopper. Pero cuando el Rey comenzó a distanciarse de la verdad, las contribuciones de Hopper fueron borradas discretamente de la historia y su caída en desgracia se aceleró. Ahora encontramos a Hopper en su celda en el Asilo HopSec.

Reglas

No compartas preguntas ni pistas, ni siquiera en videos, transmisiones ni ningún otro medio, mientras el evento esté activo (hasta el 31 de diciembre).

Solo hackea las máquinas desplegadas en las salas a las que tengas acceso legítimo y autorizado.

*.tryhackme.com y los servidores VPN están prohibidos para sondeo, escaneo o explotación.

Se permite trabajar en equipo.

Para obtener una lista más completa, consulta los Términos y Condiciones de Advent of Cyber 2025.

Acceso Inicial

Este desafío se desbloquea al encontrar la clave de la Misión Secundaria en el Día 1 de Advent of Cyber. Si has sido lo suficientemente astuto como para encontrarla, puedes desbloquear la máquina visitando MACHINE_IP:21337 e ingresando tu clave. ¡Feliz Misión Secundaria!

Escape!

Desafío de Escape del Asilo

Ahora controlas a Hopper con un objetivo final: liberarte de este encarcelamiento injusto. Para ello, debes seguir el plan de escape de 5 pasos de Hopper:

1. Desbloquea la celda de Hopper
Tu escape comienza en la zona de celdas y almacenamiento. Hopper está encerrado dentro y la puerta está asegurada con una cerradura digital. Tu primera tarea es acceder a los controles de la celda y desbloquear la puerta. Una vez que Hopper esté libre, puedes empezar a avanzar hacia el vestíbulo.
2. Atraviesa el vestíbulo
Con la celda desbloqueada, dirígete directamente al vestíbulo. Esta zona conecta los diferentes bloques de las instalaciones. Las cámaras están activas, así que mantente alerta. Tu objetivo es llegar a la entrada de la sala de psiquiatría, situada en el lado este del vestíbulo.
3. Evita el teclado de la sala de psiquiatría
La sala de psiquiatría está protegida por un sistema de teclado. Debes identificar el código correcto o usar el teclado para continuar. Una vez que el teclado esté desbloqueado, accederás al pasillo de salida de la sala de psiquiatría.
4. Llega al Corredor Principal
Desde la salida del pabellón psiquiátrico, puedes dirigirte al sur y dar una vuelta hacia el Corredor Principal. Esta es la sección final de la ruta de escape. El último desafío te espera aquí, y al completarlo se abrirá la última puerta de salida.
5. Escapa de las Instalaciones
Resuelve el último desafío en el Corredor Principal y dirígete a la salida marcada en el mapa. Una vez que la puerta se abra, Hopper quedará libre y la huida

habrá terminado.

Unlock Hopper's Memori

10.81.150.82:21337

TryHackMe | Learn Cy...TryHackMe SupportOffline CyberChefRevshell GeneratorReverse Shell Cheat S...GitHub - swisskyrepo/...

It looks like you haven't started Firefox in a while. Do you want to clean it up for a fresh, like-new experience? And by the way, welcome back!Refresh Firefox...



Unlock Hopper's Memories

Hopper's memories are locked away in a magical Easter egg.
Find the secret key to unlock them!

The key to unlock this memory can be found on Advent of Cyber - Day 1!



Unlock Hopper's Memories

Hopper's memories are locked away in a magical Easter egg.
Find the secret key to unlock them!

The key to unlock this memory can be found on Advent of Cyber - Day 1!



Memory Key:

UNLOCK MEMORIES

The bunnies are watching! Make sure you have the correct key before attempting to unlock.